Data Breach Response Guide
WyIT.2004-G1

Policy Owner	Drew Dilly, Chief Data Officer
Policy Contact	Pat Potter, Deputy Chief Data Officer
Policy Approver	Jeff Clines, Chief Information Officer
Effective Date	September 12, 2025
Next Review Date	April 1, 2027
Policy Version	2026-09.01
Associated Policy	WyIT 2004, Information Breach

Introduction:

This guide intends to guide agencies in responding to breaches of sensitive information. It is not intended to supersede or supplant relevant state or federal controlling laws, rules, policies, or regulations. ETS strongly recommends implementing guidelines relevant to specific federal controlling laws, rules, policies, or regulations.

Authority

This guideline is promulgated under the authority of Wyoming State Statute 9-2-2906 and its subsections, the Department of Enterprise Technology Services is required to adopt and enforce information technology standards, and promote efficient use of information technology throughout state government.

Specifically, this policy is further promulgated under the authority of the below listed Wyoming State Statute subsections.

- Implements and maintains an information technology governance program for state agencies (W.S 9-2-2906,(b), (ii));
- Establishes and enforces data security and privacy policies and standards for the state data infrastructure Establishes review criteria for the agencies information technology projects, procurements and purchases. (W.S 9-2-2906,(b), (iii)); and

Adopts information technology policies and standards and ensures agency compliance with those policies and standards (W.S. 9-2-2906,(b), (vi)).

Audience

This guide applies to all Executive Branch agencies, boards, and commissions staff (collectively referred to as "agencies"). This policy is also applicable to consultants, affiliates, third party vendors and temporary employees that use or store state data.

Definitions

Key Definitions, Acronyms, and Terms

Process:

1. Upon the determination of a potential breach of sensitive information:

    1.1. The agency, working with its own IT staff, vendor, and ETS, shall begin the process of removing access, limiting the breach exposure, and mitigating risk.

    1.2. The Agency Official for Privacy shall conduct a privacy risk assessment (process defined below) to determine the extent of harm to affected individuals.

    1.3. The Agency Official for Privacy shall determine whether the agency's investigation can be conducted at the staff level following the agency's own policies or whether the agency should convene a breach response team in conjunction with the State Chief Data Officer (CDO).

    1.4. The Agency Official for Privacy shall make the initial determination of the incident level in coordination with the CDO and Chief Security Officer (CSO). Incidents can be classified based on three levels:

        1.4.1. **Minor Incident**: The creation of a breach response team is not necessary. The Agency Privacy Official shall report the incident, findings, reasons for the determination, and any supporting information, such as remediation, to the CDO within 24 hours of the determination.

        1.4.2. **Moderate Incident (default level)**: The Agency Privacy Official shall initiate a breach response plan, and a breach response team must be convened. The incident shall be reported by the agency head to the Governor's Office, the State CDO within 12 hours after determination.

        1.4.3. **Major Incident**: The Agency Privacy Official, in coordination with the Chief Data Officer, shall initiate the breach response plan, and the breach response team must be convened. The incident shall be reported by the agency head to the Governor's Office within 4 hours of the determination.

2. **CONDUCT A RISK ASSESSMENT**
The Agency Privacy Official, and as necessary the CDO, shall assess the likely risk of harm caused by the breach and the level of risk created by the breach to determine the level of the incident and to produce a report on how the incident occured. The factors to be considered include:

    2.1. The nature and sensitivity of the PII potentially compromised by the breach

DRAFT

2.2. The likelihood of access and use of PII, including whether the PII was properly encrypted or rendered partially or completely inaccessible by other means

2.3. The type of breach, including the circumstances of the breach, the actors involved, and their intent

2.4. If individuals involved in an intentional breach had the objective to improperly obtain, withhold, destroy, or release the information or the device guarding the information (e.g., a laptop or mobile device), the risk of harm to the affected individuals and the agency will generally be greater

2.5. There may be less risk of harm when a breach is unintentional, such as by user error or by failure to obey agency policy

2.6. In situations where it is difficult to determine whether a breach was intentional or unintentional, the agency may decide to treat the incident as intentional based on factors such as who received compromised PII

2.7. Risk levels are defined as follows:

2.7.1. **Low**: The loss of confidentiality, integrity, or availability is expected to have a limited adverse effect on organizational operations, organization assets, or individuals. Breach incidents may be defined as Low if there was no failure of an IT security control, such as an individual exposing their own sensitive PII.

2.7.2. **Moderate:** The loss of confidentiality, integrity, or availability is expected to have a serious adverse effect on organizational operations, organization assets, or individuals.

2.7.3. **High:** The loss of confidentiality, integrity, or availability is expected to have a severe or catastrophic adverse effect on organizational operations, organization assets, or individuals.

3. CREATING THE BREACH RESPONSE PLAN

To effectively and efficiently respond to a breach, the Agency Official for Privacy, and as necessary the Chief Data Officer, shall develop and implement a breach response plan. The plan should be a formal document that includes the agency's policies and procedures for reporting, investigating, and managing a breach, tailored to the agency's missions, size, structure, and functions. At a minimum, a breach response plan shall include the following elements:

3.1. The breach response team, including the specific agency officials who comprise the team and their respective roles and responsibilities when responding to a breach.

DRAFT

3.2. Identification of applicable privacy compliance documentation, including the responsibility to identify any laws, regulations, privacy acts, privacy impact assessments (PIAs), and privacy notices that may apply to the potentially compromised information.

3.3. Information sharing procedures to respond to a breach, including potential information sharing within the agency or between agencies that may arise following a breach to reconcile or eliminate duplicate records, to identify potentially affected individuals, or to obtain contact information to notify potentially affected individuals.

3.4. Reporting requirements, including the specific agency officials responsible for reporting a breach to oversight entities and the Governor's Office, when appropriate.

3.5. Procedures for assessing the risk of harm to individuals potentially affected by a breach, including the factors the agency shall consider when assessing the risk.

3.6. Plans for mitigating the risk of harm to individuals potentially affected by a breach, including whether the agency should provide guidance to potentially affected individuals, purchase identity theft services for them, and offer methods for acquiring such services.

3.7. Procedures for notifying individuals potentially affected by a breach, including if, when, and how to provide notification to potentially affected individuals and other relevant entities.

4. CREATING THE BREACH RESPONSE PLAN

The agency's breach response team is the group of agency officials designated by the head of the agency. Once convened, the Agency Official for Privacy is responsible for leading the breach response team and coordinating with the Chief Data Officer as necessary. The criteria for convening the breach response team shall be documented in the agency's breach policy. The criteria may differ for each agency according to its individual missions, specific authorities, circumstances, and risks. At a minimum, the agency's breach response team shall include:

4.1. Director or delegated authority

4.2. Agency Official for Privacy

4.3. Agency Legal Counsel

4.4. Communications official (or their functional equivalents)

5. MITIGATING THE RISK OF HARM

5.1. Once the level of risk has been identified, the breach response team shall consider how best to mitigate the identified risks.

The team is responsible for advising the Agency Privacy Official on an appropriate response plan.

DRAFT

5.2. When determining how to mitigate the risk of harm to individuals potentially affected by a breach, the agency shall consider what countermeasures it can take, what guidance to provide to affected individuals, and whether there are services the agency can provide.

5.3. The breach response team shall determine whether notice to affected individuals is warranted, balancing transparency with the risk that over-messaging could dilute the seriousness and effectiveness of statutory notifications. Notice is required when guidance, countermeasures, or services are offered, but may also be appropriate when it enables individuals to take justified remedial action based on the risk.

6. NOTIFICATION OF AFFECTED INDIVIDUAL(S)

Upon determining that a breach notification to the affected individual(s) is warranted, the breach response team shall consider the following factors:

6.1. Who shall provide the notification to the affected individual(s)?

6.2. When should notification be provided?

6.3. What should be included in the notification to the affected individual(s)?

7. WHO SHOULD PROVIDE THE NOTIFICATION?

7.1. Notification to individuals affected by the breach shall be issued by the Director of the agency or an Agency designee acting on their behalf.

This demonstrates that the breach has the attention of the head of the agency.

7.2. Notification involving only a limited number of individuals may also be issued by the Agency Official for Privacy.

7.3. When PII created, collected, used, processed, stored, maintained, disseminated, disclosed, or disposed of by a contractor on behalf of an agency is involved in a breach, the director may require the contractor to notify any potentially affected individuals.

8. WHEN SHOULD NOTIFICATION BE PROVIDED

8.1. If it is determined that notification to the individual(s) affected by a suspected or confirmed breach of PII is warranted, the notification shall be provided as quickly as possible and without unreasonable delay.

8.2. The breach response team should avoid making multiple notifications for a single breach, and should balance the timeliness of the notification with the need to gather and confirm information about a breach and assess the risk of harm.

9. WHAT SHOULD BE INCLUDED IN THE NOTIFICATION?

Every notification must be provided in writing and be written in a format that is clear and easy for

DRAFT

the recipient to understand. Every notification shall include the following elements:

9.1. A brief description of what happened, including the date(s) of the breach and of its discovery.

9.2. A description of the types of PII compromised by the breach, to the extent possible.

9.3. A statement of whether the information was encrypted or protected by other means when it is determined that disclosing such information would be beneficial to potentially affected individuals and would not compromise the security of the information system.

9.4. Guidance to potentially affected individuals on how they can mitigate their own risk of harm, countermeasures the agency is taking, and services the agency is providing to potentially affected individuals, if any.

9.5. Steps the agency is taking, if any, to investigate the breach, mitigate losses, and protect against a future breach.

9.6. Contact information for the agency, including a telephone number, email address, and postal address, that potentially affected individuals can use to obtain additional information.

Applicable State Policies, Federal, State or Industry Rules, Laws, and/or Regulations

1. WyIT 2002, Data Protection for Electronic Government Services
2. WyIT 2004, Information Breach, Disclosure, or Data Leak
3. WyIT 2006, Agency Official for Privacy (AOP)
4. WyIT 2011, Wyoming State Data Collection, Transparency, and Consent

Compliance & Exceptions:

Compliance

This document supports an established policy, so there are no compliance requirements.

Exceptions

Since standards are not held to a compliance standard, there are no exceptions to this standard.

Review/Approval:

Date Issued/Review Date

This policy shall be reviewed at least annually and updated / reviewed / approved as defined in the Office of Chief Information Officer (OCIO) Policy lifecycle.

The review and update process shall be coordinated by Governance, Risk and Compliance (GRC), completed by the policy owner and approved through the OCIO policy review workflow.

DRAFT

Approval

This policy as signed by the appropriate officer (listed below) is considered approved and enforced, per Wyoming State Statutes (W.S 9-2-2906,(b), (iii)) and (W.S. 9-2-2906,(b), (vi)).

To obtain a signed copy of this document, contact Enterprise Technology Services Governance, Risk and Compliance (ets-ocio-grc@wyo.gov).

Jeffrey Clines Officer Name	Chief Information Officer Officer Title
_____ Officer's Signature	_____ Date

Revision History

The current version of this policy, as identified in the Revision History below, supersedes all previous documents listed below.

Version	Change	Author(s)	Date of Change
2026-09.1	ETS Director signature	GRC	September 2026
2025-09.1	WyIT 2004-GL, Information Breach Response Guideline, Migrated to New Template	Pat Potter, Deputy CDO	September 2025
UKN	WyIT 2004-GL, Information Breach Response Guideline, Originally Published	Pat Potter, Deputy CDO	August 2024

DRAFT